AGH University of Krakow
Faculty of Computer Science, Electronics and Telecommunications
Cybersecurity

Client
Broken Crystals

Web Application Threat Model

Version 1

Contributors
Mateusz Okoń, Bogdan Khmelnitskiy, Patryk Harasik

Krakow, March 17, 2026

1 System description

Broken Crystals is a web application that enables user registration and login, access to a crystal marketplace, a opinion and private messaging system, access to the currently logged-in user's panel, and modification of user data. The system processes several key assets critical to the organization, including the user personal data and the order and marketplace database. The system operates online at brokencrystals[.]com. The modelled system is a test environment, however, the data used for testing is equivalent in structure and sensitivity to production data.

2 Scope

The scope of the assessment comprised of:

URL	Description
hxxps[://]brokencrystals[.]com	Home page
hxxps[://]brokencrystals[.]com/marketplace	Marketplace
hxxps[://]brokencrystals[.]com/userprofile	Current user data modification page
hxxps[://]brokencrystals[.]com/chat	Current user private chat
hxxps[://]brokencrystals[.]com/userlogin	User sign in page
hxxps[://]brokencrystals[.]com/newuserlogin	User 2-step sign in page
hxxps[://]brokencrystals[.]com/dashboard	Admin dashboard
hxxps[://]brokencrystals[.]com/adminpage	Admin user catalog
hxxps[://]brokencrystals[.]com/grahiql	Web application tool for writing, validating, and testing GraphQL queries
hxxps[://]brokencrystals[.]com/swagger/*	Broken Crystals REST API
hxxps[://]brokencrystals[.]com/api/*	Broken Crystal APIs

Available endpoints	Description
App	Common operations
Auth	Operations with authentication methods
User	Operations with users (creation, searching)
Files	Operations with files
Subscriptions	Operations with subscriptions
Testimonials	Operations with testimonials
Products	Operations with products
Partners	Operations with partners
Emails	Operations with emails
Chat	Operations with chat

3 Main Components / System Architecture

3.1 Physical Components

- API / backend servers
- Database server
- End-user and administrator devices
- Test environment network infrastructure devices.

3.2 Virtual Components

- Web frontend (brokencrystals.com)
- Backend / REST API and GraphQL (/api/, /graphiql)
- Admin panel
- Database
- Website user authentication system
- Test environment
- Temporary code repository (only fragments of code)

3.3 Application Functionality

Unauthenticated user can:

- view most frequently asked questions (public FAQ),
- join the newsletter (public form),
- contact site owners via contact form (Home page - bottom section),
- use the location map (Home page - bottom section),
- create an account,
- log in using a single-step form (email + password) or two-step login (step 1: email, step 2: password).

Authenticated user can:

- perform all actions of an unauthenticated user except account creation and login (user is already logged),
- log out,
- manage their profile (change first name, last name, email address, add/remove profile picture),
- browse items on the marketplace,
- filter marketplace items (by date, crystal type, keywords - search bar in Marketplace),
- submit reviews for products or the company (bottom of Marketplace page - reviews section),
- submit feedback (form at the bottom of the Marketplace page),
- send and receive private messages.

Administrator can:

- perform actions of an unauthenticated and authenticated user except account creation and login (admin is already authenticated),
- access the admin panel,
- view the list of users (admin panel - user catalogue),
- view user data (first name, last name, email, company name),
- search for users via search bar (admin panel – user catalogue).

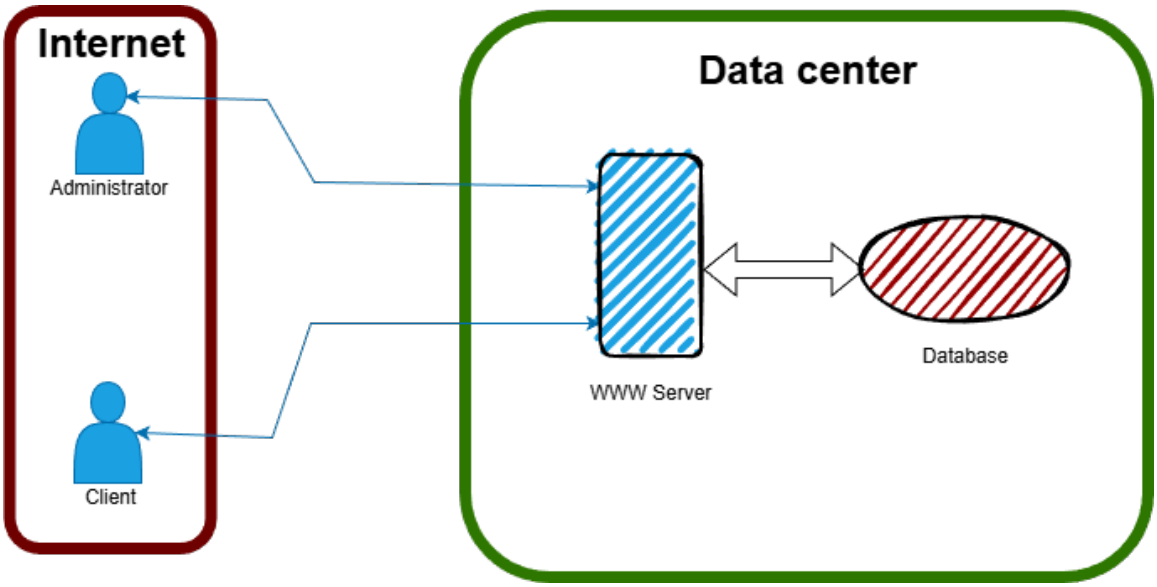

Figure 1: A diagram illustrating the structure of an online marketplace with marked trust boundaries.

4 Assets

- Reviews
- Contact messages
- User data
- Feedback (uploaded files)
- Location map
- Newsletter subscription system
- Internal administrator account
- User account
- Admin panel
- API
- Fragments of user authentication source code (/src/auth/*)
- User profile photos
- Private chat system
- Test API keys and tokens
- Test environment
- Company reputation

5 Actors

- User with account (authenticated user)
- User without account (unauthenticated user)
- Internal administrator account
- Security tester
- External attacker
- A malicious actor from within the company

6 Diagrams

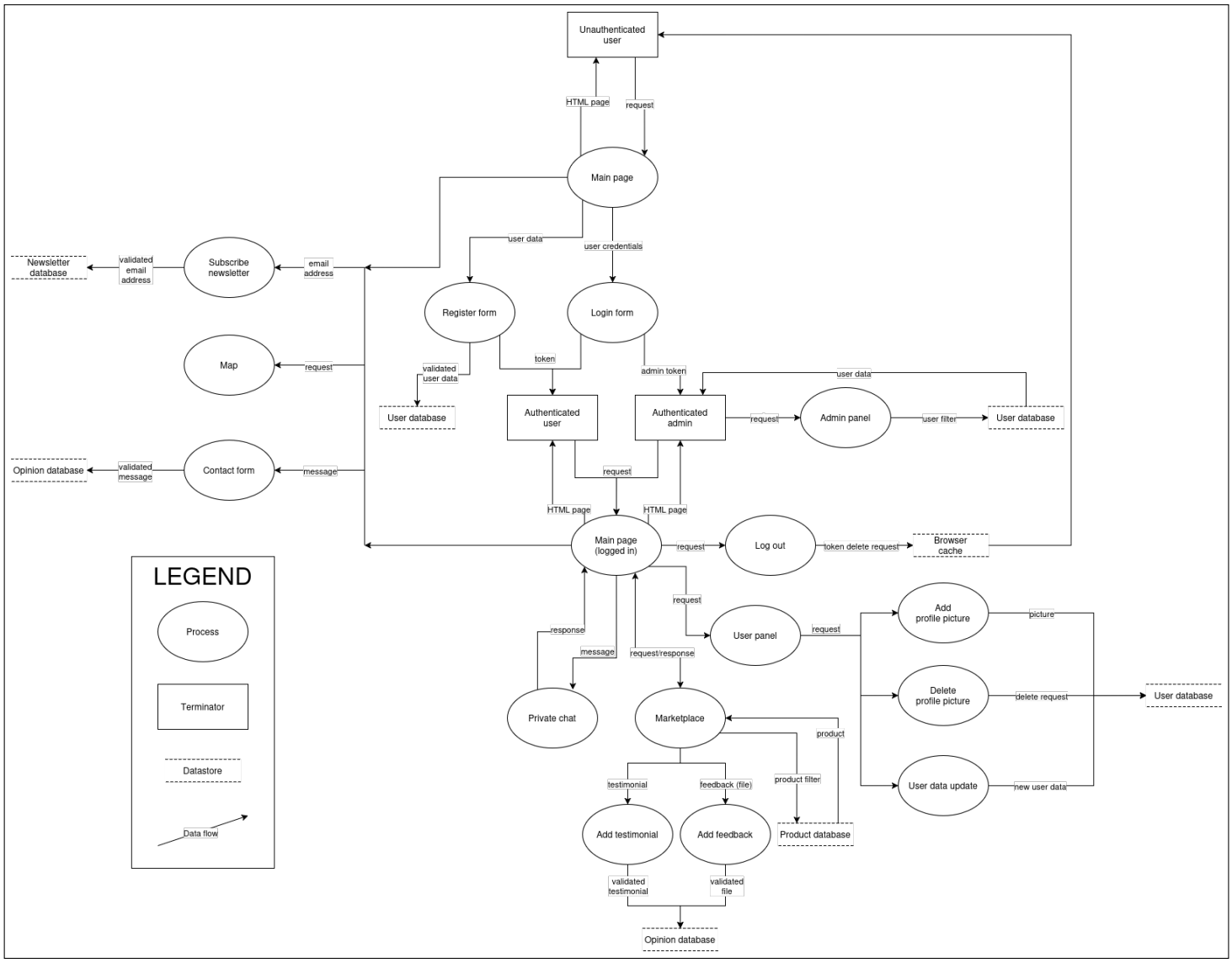

Figure 2: Data Flow Diagram

Trust Boundaries:
User → Application: Data from users is untrusted and must be validated before processing.
Frontend → Backend: The server cannot trust client-side logic, all actions require server-side verification.
Backend → Database: Only sanitized, authorized operations should cross into the database layer.
User Role → Admin Role: Privileged functions must be isolated, no user should cross this boundary without explicit authorization.
Internal System → External Services: Communication with third-party APIs requires validation, authentication, and error handling.
Application Admin → Infrastructure Admin: Application administrators must not have implicit access to infrastructure or system-level privileges.
Application → Infrastructure: The application layer must not have unrestricted access to the underlying infrastructure.
Application Administrators → Database Administrators: Application-level administrators must not have database-level privileges.

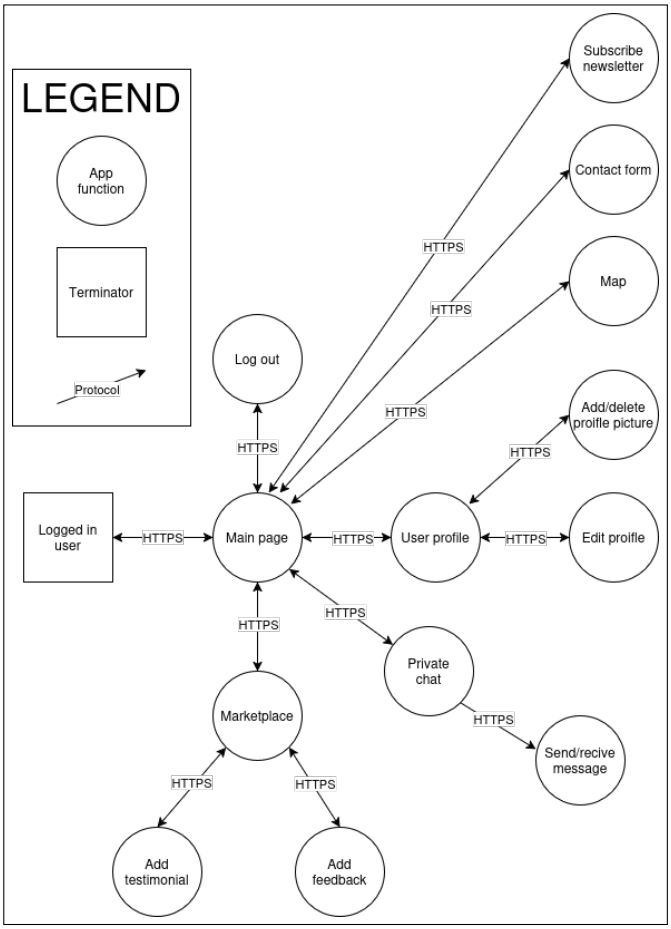

Figure 3: Process Flow Diagram for an authenticated user

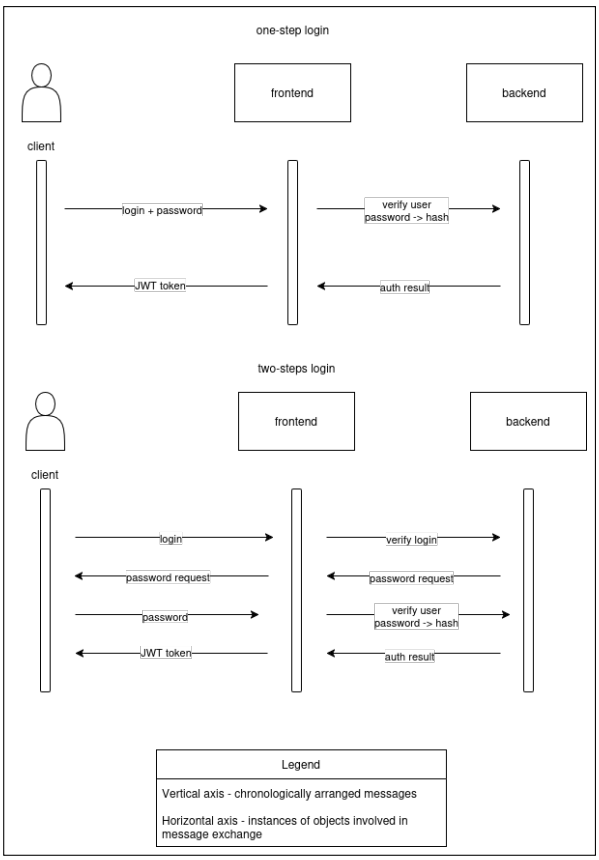

Figure 4: Sequence diagram illustrating the login process in the web application

7 Threat Identification

7.1 STRIDE Categories Mapped to Objects

	S (SPOOFING)	T (TAMPERING)	R (REPUDIATION)	I (INFORMATION DISCLOSURE)	D (DENIAL OF SERVICE)	E (ELEVATION OF PRIVILEGE)
external entity	x		x			
process	x	x	x	x	x	x
data flow		x		x	x	
data store				x	x	x

7.2 STRIDE Threats

7.2.1 SPOOFING

Scenario	Description	CWE	Possible Impact
JWT Bypass	Creating a forged JWT without a valid signature	CWE-287 CWE-347	User or administrator account takeover
JWT *kid* Manipulation	Modifying the *kid* field to reference attacker-controlled keys	CWE-829	Unauthorised login
Brute-force login	Password guessing attacks	CWE-307	User account compromise
Default admin credentials	Administrator login using known default credentials	CWE-1188	Access to the administrative panel
SSRF	SSRF allows access to internal services and infrastructure metadata	CWE-918	Access to internal infrastructure

7.2.2 TAMPERING

Scenario	Description	CWE	Possible Impact
SSTI	Code injection within a server-side template	CWE-94	Data modification, RCE
SQL Injection	Manipulation of SQL queries	CWE-89	Modification of user or product data
XPATH Injection	Forgery of XML structure	CWE-643	Modification of partner data
Prototype Pollution	Modification of JavaScript object prototypes	CWE-1321	Altered application logic
Unsafe file upload	Uploading malicious files	CWE-434	Resource replacement, attack escalation
Mass Assignment	Adding hidden fields in JSON	CWE-915	Unauthorised privilege changes

7.2.3 REPUDIATION

Scenario	Description	CWE	Possible Impact
Lack of user activity logs	User actions are not recorded	CWE-778	No evidence of malicious user activity
Endpoints accessible without authentication	Operations performed anonymously	CWE-306	Inability to identify the perpetrator
Lack of administrator activity logs	Administrator actions are not recorded	CWE-778	No evidence of malicious administrative activity
XSS	Code executed on the victim's side	CWE-79	Difficulty attributing the attack
Lack of audit logs	Security-relevant events are not recorded	CWE-223	The source of an attack will be difficult or impossible to determine.

7.2.4 INFORMATION DISCLOSURE

Scenario	Description	CWE	Possible Impact
SQL Injection	Ability to retrieve database contents	CWE-89	Leakage of personal data
LFI / File Read API	Reading arbitrary files	CWE-98 CWE-552	Leakage of configuration and keys
Configuration exposure	Endpoint returns the application configuration	CWE-200 CWE-209	Full compromise of the application
CORS = *	Third-party websites can read responses	CWE-942	User data leakage
Full Path Disclosure	Server shows errors and file paths	CWE-209	Information about the environment
XSS	JavaScript attack in the browser	CWE-79	Session takeover

7.2.5 DENIAL OF SERVICE

Scenario	Description	CWE	Possible Impact
Date Manipulation	Extremely large date ranges may overload the database	CWE-770	Slowdown or crash of the server
Massive Messaging / Newsletter Abuse	Sending large amounts of messages or having a high number of subscribers overloads the system	CWE-770	Service suspension
Large file upload	No file size limits	CWE-770	Storage exhaustion
SSRF	Server makes requests to itself	CWE-918	Infrastructure overload
HTTP Method Fuzzer	Unsupported HTTP methods	CWE-749	Server errors, overload

7.2.6 ELEVATION OF PRIVILEGE

Scenario	Description	CWE	Possible Impact
Mass Assignment	A hidden field grants privileges	CWE-915	Obtaining admin role
JWT attacks	Creating one's own admin tokens	CWE-347	Compromise of the admin panel
Broken Function Authorisation	Deleting information belonging to other users	CWE-862	Unauthorised administrative actions
ID Enumeration	Reading data from other users' accounts	CWE-203	Unauthorised access
SSRF to internal services	Gaining access to unauthenticated internal panels	CWE-918	Infrastructure compromise
RCE	Code executed on the server side	CWE-94	Full control over the system

8 Risk Assessment

Threat	CWE ID	Likelihood	Impact	Priority	Proposed Mitigations
Broken Function Authorisation	CWE-862	**High**	Unauthorised operations (e.g. deleting resources, viewing others' data)	**High**	• Permission validation for every function • RBAC/ABAC • IDOR testing + resource ownership checks • Access restrictions based on identifiers
JWT Bypass	CWE-347	**Medium**	Account or administrator account takeover	**High**	• Enforce a single algorithm (RS256) • Reject tokens with alg=none • Key rotation, HSM/KMS • Monitoring of unusual tokens
SQL Injection	CWE-89	**Medium**	Full data leak, ability to modify the database	**High**	• Parameterised queries • ORM reducing string concatenation • WAF + SQLi pattern detection

9 Recommendations - Priority Security Tests

Area	What to Test
Authentication and Authorization	JWT testing, login flows, IDOR, user/admin privileges
API and Backend	SQL Injection, XSS, input validation
Data Access	Data leaks, CORS, configuration errors, cross-user access
File Uploads	File size limits, file types, possible code execution

10 Conclusions

The analysis revealed multiple areas within the system that are vulnerable to data tampering, unauthorized access, and potential information leakage. Implementing appropriate security controls in the API, authentication mechanisms, and access control policies will significantly mitigate these risks.

Furthermore, the assessment shows that there may be several injection vulnerabilities that could allow attackers to manipulate application input, bypass security measures, or gain access to unintended data. To prevent these vulnerabilities from being exploited, it is necessary to strengthen input validation, parameter handling, and cleanup on the server side.